

TLP:GREEN — FS-SECTOR INTERNAL DISTRIBUTION

April 2026 Financial Sector Threat Intelligence — Monthly Brief

*Sector-focused month-in-review for FS CISO / RT /
DE distribution*

2026-04-28

Audit passes: 2 (independent reviewers) · Quality: A · Status: ready-pending-review

Contents

April 2026 Financial Sector Threat Intelligence — Monthly Brief	1
Executive BLUF (1 page)	1
Analytic Tradecraft Standards (ICD 203 / 207 alignment)	2
THREATCON Determination — End of April 2026	3
Month-in-Review — Cycle Cadence + Posture Trend	5
Top 10 Cycle Events of the Month	6
New Campaign-Class Labels Promoted This Month	7
Active Campaigns — Status Roll-Up	8
Top Adversaries by Tempo	10
CVE Landscape — April Disposition	11
Predictive Intelligence — Q3 Forward Emulation Queue	12
Q2 Purple-Team Pipeline Progress (sector reference cadence)	12
Decisions Queue — End-of-Month State (recurring CISO-tier items)	13
Carry-Over Tracker — End-of-Month Disposition (full inventory)	14
Strategic Implications for FS CISO — May–June	14
Recommended May–June Focus	15
Recurring Monthly Template Spec (v1.1)	15
Sources	16

April 2026 Financial Sector Threat Intelligence — Monthly Brief

Period covered: 2026-04-01 → 2026-04-28 · **Sector posture:** HIGH (current cycle); HIGH-band peaked Apr 27 at composite 0.75; tabletop trigger crossed Apr 27-28 · **Audience:** FS CISO primary

Executive BLUF (1 page)

April 2026 was the inflection month for the financial services sector. Four macro shifts that had been individually trending for 6-12 months converged into simultaneous baseline conditions: software-supply-chain attacks **industrialized** (the TeamPCP + Vect partnership mobilized 300K BreachForums affiliates and compromised 66+ npm packages plus Trivy + Checkmarx + LiteLLM + Telnix + the European Commission AWS environment; in parallel, DPRK / UNC1069 / Lazarus ran 1,700+ malicious packages across npm/PyPI/Go/Rust); patch-window collapse **became default** (the Marimo CVE-2026-39987 was weaponized in 9 hours; Storm-1175 demonstrated pre-disclosure exploitation); OAuth supply-chain cascades moved from boutique-APT capability to **mainstream tradecraft** (Vercel-Context.ai cascade + Microsoft April 18 cross-tenant playbook); and AI-acceleration is **now the adversary baseline** (Vercel CEO public attribution + Wordfence reporting AI-assisted vulnerability submissions grew from 16% to 66% of total volume, a +453% absolute increase). Two new campaign-class labels were promoted to formal tracking this month: **DEFENDER-STACK-PATTERN** (sustained: CrowdStrike LogScale CVE-2026-40050 + BSI/CERT-Bund EDR Kaufratgeber + **BlueHammer / RedSun / UnDefend Windows Defender zero-days from “Nightmare-Eclipse” toolset (Huntress in-the-wild Apr 16-20) + PoisonKiller signed-driver Falcon-killer**); and **POST-AUTH-TRUST** (AiTM post-auth + agentic identity + RAG pipelines + identity-as-perimeter convergence; estimated \$15-100M exposure ceiling per FS firm — **likely exceeds risk appetite at most sector firms**).

Three convergences create direct sector exposure for May–June: (1) **the 2016 broker-dealer helpdesk-vishing breach pattern (the SEC Reg-S-ID enforcement-precedent class)** has been reactivated by Microsoft’s April 18 cross-tenant helpdesk-impersonation playbook publication, with the NY DFS February 6 vishing advisory now operationally relevant and active SLISH female-voice-visher recruitment confirmed (Dataminr, February 22) — and freshly

extended by **UNC6692 (Mandiant A-1, 33 multi-source mentions): Microsoft Teams IT-helpdesk impersonation + email-bombing chains with custom SNOW malware suite**; (2) **third-party vendor surfaces** common across the sector (iPaaS / GitHub / npm/PyPI / Drupal CMS / WAF / cert-management / DAM / VS Code extensions / SimpleHelp RMM) sit squarely inside TeamPCP's target class — Update 008 (April 27) ended an approximately three-week pause with three concurrent compromises (Checkmarx KICS, Bitwarden CLI, xinferance PyPI) plus a new self-propagating npm worm “CanisterSprawl” — and is reinforced by **GlassWorm v2 / OpenVSX 73 fake VS Code extensions** + the **CISA Apr 24 KEV batch** (SimpleHelp + Samsung + D-Link); (3) **Akira ransomware operator surge** (49 April mentions, 84 victims in March, two insurers struck in 24 hours, **86% of Akira intrusions traced to SonicWall SSL VPN CVE-2024-40766**) shifts insurance-vertical FS-direct ransomware risk from theoretical to operational.

The sector intelligence library expanded by **four new threat-actor cards** this month (Stonefly DPRK, BlackFile, Akira, Play); a post-audit authorship sprint adds UNC6692, UAT-4356 (Cisco Firestarter firmware-resident backdoor), and 5 others to close the late-April BLUF backlog. The forward emulation queue puts TeamPCP supply-chain → iPaaS data-exfil at top of the Q3 promotion stack. Standing CISO decisions queued at sector firms running this brief: helpdesk-vishing purple-team session approval, OAuth grant audit prioritization, voice-biometric vendor evaluation budget, third-party-risk vendor concentration audit (geo-concentration + RMM concentration), and stealer-log marketplace monitoring posture.

Analytic Tradecraft Standards (ICD 203 / 207 alignment)

Probability calibration key (ICD 203)

All assessments use these terms with their defined probability bands. Confidence terms (“high/medium/low confidence”) are forbidden without an explicit basis statement.

Almost certain	95%+
Very likely	80–95%
Likely	55–80%
Roughly even	45–55%
Unlikely	20–45%
Very unlikely	5–20%
Remote	<5%

Admiralty source reliability ratings (ICD 206)

A = Completely reliable (CISA, MSTIC, Unit 42, Talos, NVD, Mandiant)	1 = Confirmed by independent A-rated sources
B = Usually reliable (BleepingComputer, Hacker News, Recorded Future, Google TAG, Huntress)	2 = Probably true (A-rated single-source or multiple B-rated)
C = Fairly reliable (PacketStorm, Exploit-DB, SANS ISC, Schneier)	3 = Possibly true (single B/C, uncorroborated)
D = Not usually reliable (single anonymous source, unverified blog)	

Analytic methodology applied (ICD 203 / 207)

- **Analysis of Competing Hypotheses (ACH)** applied to all P1 items (minimum 3 hypotheses; per-cycle worksheets in cycle-delta briefs)

- **Key Assumptions Check (KAC)** with explicit invalidation indicators — see next section
- **Devil's advocacy** flagged for single-source claims (see KA-3 + KA-7)
- **Distinction between fact and judgment:** facts use indicative voice; judgments use “we assess” / “we judge” with explicit basis
- **Cross-cycle continuity:** pattern detection requires 2-3 cycle corroboration before campaign-class promotion (POST-AUTH-TRUST currently in 1-cycle emergence; awaits corroboration)
- **Statistical-anomaly threshold:** entity mention frequency exceeding $+2\sigma$ from 30-day rolling average is flagged as breakout

Key Assumptions Check — KA-1..KA-7 (with invalidation indicators)

KA	Assumption	Invalidation indicator
KA-1	DEFENDER-STACK-PATTERN evidence (LogScale CVE + BSI/CERT-Bund EDR analysis + BlueHammer/RedSun/UnDefend + PoisonKiller) reflects sustained adversary intent to target defender stacks, not coincidental clustering	Closure of all 3 active sub-threads (LogScale patched + Defender zero-days suppressed + PoisonKiller IOCs retired) within 30 days without replacement
KA-2	POST-AUTH-TRUST 4-source convergence reflects an emerging campaign-class, not noise from analyst attention	Failure to observe a 5th independent source by end of May (downgrade to candidate-pattern)
KA-3	Vercel-Context.ai BreachForums sale (\$2M) is real (currently single-source: r/sysadmin aggregator + BreachForums verified — devil's advocacy applied)	Subsequent disclosure that the sale post is a re-listing of prior public data, or no buyer materializes within 30 days
KA-4	TeamPCP 19-day pause was deliberate operational discipline, not group disruption	Update 008 IOC reuse from pre-pause infrastructure (would suggest infrastructure was never burned)
KA-5	Akira insurance-vertical surge reflects deliberate sector targeting	If May data shows insurance victim count regression to mean ($<10/\text{month}$), revise to “April outlier”
KA-6	UNC6692 SNOW malware represents a distinct toolset from other helpdesk-impersonation actors	Subsequent attribution merging UNC6692 into UNC3944 / Scattered Spider cluster
KA-7	Marimo CVE 9-hour weaponization is reproducible AI-acceleration baseline, not a one-off (currently single-incident — devil's advocacy applied)	If May/June produces zero sub-12-hour weaponizations, downgrade to “AI-accelerated edge case”

Production standards

This brief was reviewed by 2 independent auditors before distribution. All claimed sources are inventoried in the source register. Cross-cycle deltas are measured against the prior-month baseline. Statistical anomalies ($>2\sigma$) are flagged.

THREATCON Determination — End of April 2026

THREATCON is computed from five weighted indicators per cycle. Composite ≥ 0.50 = HIGH. **Current sector THREATCON: HIGH (composite 0.65).**

Indicators & Warnings (I&W) Matrix

ID	Indicator	Weight	Status	Source	Last change
I&W-1	Active exploitation of perimeter devices in financial sector	0.30	LIT	CISA KEV (A-1) — FortiClient EMS, Ivanti EPMM, Cisco IMC, SimpleHelp KEV batch	Apr 25 (Cisco IMC + SimpleHelp KEV)
I&W-2	Nation-state identity infrastructure compromise	0.25	LIT	TA416/DarkPeony OAuth diplomatic targeting; MS Entra Agent ID flaw (A-1); UNC6692 SNOW (Mandiant A-1)	Apr 26 (Entra Agent ID); Apr 21 (UNC6692)
I&W-3	3+ threat vectors simultaneously targeting FS sector	0.20	LIT	Ransomware (Akira/Qilin/Storm-1175) + supply-chain (TeamPCP/UNC1069) + OAuth (Vercel-class) + helpdesk-vishing (TEAMSTORM/UNC6692) + defender-stack (DEFENDER-STACK-PATTERN)	Apr 1 (sustained)
I&W-4	Targeted activity against specific FS firm personnel	0.15	UNLIT (default)	Requires per-firm internal telemetry — check internal SOC	N/A
I&W-5	Scanning of FS firm infrastructure from known APT IPs	0.10	UNLIT (default)	Requires per-firm internal telemetry — check perimeter logs	N/A

Composite calculation: $0.30 + 0.25 + 0.20 = 0.65$ (HIGH band: 0.50–0.74)

Threshold reference: NORMAL <0.25 / ELEVATED 0.25–0.49 / **HIGH 0.50–0.74** ← current / CRITICAL ≥0.75

Cycle-on-cycle trend (per cycle-delta briefs): - **Apr 25:** ELEVATED (composite 0.45) — April-MTD baseline established - **Apr 26:** STEADY (composite ~0.30) — single-actionable post-mega-catchup cycle - **Apr 27:** HIGH (composite 0.75 peak — boundary CRITICAL; 4 P1 items) - **Apr 28:** HIGH (composite 0.65 — third HIGH-class cycle counting back to mega-catchup baseline)

Tabletop trigger (THREATCON HIGH + ≥2 P1 items in same sector): **CROSSED Apr 27 and Apr 28 (2 consecutive cycles)**. FS firms that have not executed a 2026 destructive-class tabletop are now overdue.

Forward 30-day forecast (calibrated): We assess it is **likely** (55-80%; A-rated multi-source corroboration on most lit indicators; ACH applied; KA-1, KA-2, KA-7 flagged) that THREATCON will sustain in the HIGH band (0.50–0.74) through end of May. Invalidation indicator: simultaneous closure of 3+ active campaign-class labels (currently 13 expanding). Probability of de-escalation to ELEVATED before June: **unlikely** (20–45%).

Month-in-Review — Cycle Cadence + Posture Trend

April 2026 — FS-Sector Operating Posture Timeline

Apr 1-9	ELEVATED 0.40 — April baseline established
Apr 10-24	HIGH — Marimo CVE 9-hour weaponization + TeamPCP wave + BlueHammer/RedSun/UnDefend ITW
Apr 25	ELEVATED 0.45 — April-MTD baseline (post mega-catchup)
Apr 26	STEADY 0.30 — single-actionable cycle
Apr 27	HIGH 0.75 PEAK — boundary CRITICAL; 4 P1 items; tabletop trigger crossed
Apr 28	HIGH 0.65 — third HIGH-class cycle; tabletop trigger sustained

Major events

Apr 10	Marimo CVE-2026-39987 9-hour weaponization (AI-accelerated)
Apr 16-20	BlueHammer / RedSun / UnDefend Defender 0-days — Huntress ITW (FortiGate VPN entry chain)
Apr 18	Microsoft cross-tenant helpdesk-impersonation playbook published
Apr 19	Vercel-Context.ai OAuth supply-chain cascade (\$2M BreachForums sale)
Apr 21	UNC6692 / SNOW malware (Mandiant A-1)
Apr 24	CISA SimpleHelp + Samsung + D-Link KEV batch
Apr 27	TeamPCP Update 008 reactivation + CanisterSprawl npm worm
Apr 28	POST-AUTH-TRUST emergence (4-source convergence)

Cycle cadence this month: 9 daily April BLUF cycles + 1 mega-catchup synthesis (April 11-25) + 1 monthly rollup + 1 master synthesis = **12 BLUF products synthesized** (per BLUF master frontmatter). Daily-cycle resumption (April 26) closed the 15-day generation gap.

Top 10 Cycle Events of the Month

Apr 10	Marimo CVE-2026-39987 weaponized in 9 hours (AI-accelerated)	Detection-first doctrine required across the sector; patch-first insufficient
Apr 16-20	BlueHammer / RedSun / UnDefend Windows Defender zero-days dropped by researcher “Chaotic Eclipse” as Nightmare-Eclipse tooling; Huntress observed in-the-wild exploitation Apr 16-20 (FortiGate VPN entry chain)	Defender stack itself is the target. Direct DEFENDER-STACK-PATTERN reinforcement
Apr 18	Microsoft cross-tenant helpdesk-impersonation playbook published	Direct codification of the 2016 broker-dealer helpdesk-phishing breach class — relevant to every FS firm with cloud helpdesk integration
Apr 19-26	Vercel-Context.ai OAuth supply-chain cascade (\$2M BreachForums sale; KA-3 single-source flagged)	Family-agnostic OAuth grant audit warranted across Entra + Okta + Salesforce + Atlassian environments
Apr 21	UNC6692 disclosed by Mandiant: Microsoft Teams IT-helpdesk impersonation + email bombing → custom SNOW malware suite + cloud abuse	TEAMSTORM reinforcement; identity-plane attack with Google A-1 attribution = exceeds typical FS firm risk appetite
Apr 22	PoisonKiller signed-driver kills CrowdStrike Falcon (BYOVD)	Direct DEFENDER-STACK-PATTERN reinforcement; FS firms running Falcon = direct exposure
Apr 24	CISA KEV batch: SimpleHelp (RMM platform) + Samsung + D-Link with May 2026 federal deadline	RMM-platform abuse = Storm-1175 phishing-to-RMM playbook adjacency; third-party-RMM concentration audit warranted
Apr 24-28	UAT-4356 / Cisco Firestarter — persistent firmware-resident backdoor on Cisco firewalls; cold-start required to clear; survives patching (Talos A-1 + CISA + UK NCSC joint)	Defender-perimeter compromise; firms with Cisco-stack perimeter = direct exposure
Apr 27	TeamPCP Update 008 — ~3-week pause ends with 3 concurrent compromises (Checkmarx KICS, Bitwarden CLI, xinferrence PyPI) + CanisterSprawl npm worm	Sector-wide vendor-stack validation — SCA tooling + GitHub PAT + npm/PyPI publish-token audits
Apr 28	POST-AUTH-TRUST emerging campaign-class — 4-source convergence	\$15-100M per-firm exposure ceiling — likely exceeds risk appetite at most sector firms

New Campaign-Class Labels Promoted This Month

PROMOTED — sustained 2+ cycle	CANDIDATE — 1-cycle	EXISTING — prior months
DEFENDER-STACK-PATTERN 2-cycle sustained · 4 evidence streams LogScale CVE + BSI EDR + Blue-Hammer/RedSun/UnDefend + PoisonKiller \$5-25M exposure	POST-AUTH-TRUST 4-source convergence (1 cycle) AiTM post-auth + agentic ID + RAG + identity-as-perimeter \$15-100M EXCEEDS appetite	PCPCAT TeamPCP REACTIVATED Apr 27 · Update 008 + CanisterSprawl worm VERCEL-CASCADE Family-agnostic OAuth cascade TEAMSTORM 2016 SEC precedent reactivation FROSTARMADA APT28 SOHO-router 5K+ OPERATION-EPIC-FURY Iran 144 finserv attacks

POST-AUTH-TRUST overlaps VERCEL-CASCADE conceptually · DEFENDER-STACK-PATTERN reinforced by Falcon-LogScale + NVD enrichment scaleback · TeamPCP sustained pressure on FS vendor stacks (iPaaS / GitHub / npm / VS Code / SimpleHelp).

POST-AUTH-TRUST methodological note: per ICD 203 cross-cycle continuity standard, POST-AUTH-TRUST is currently a **candidate campaign-class label** awaiting 2-3 cycle corroboration. The brief tracks it under candidate status; it is not yet a confirmed promotion.

Active Campaigns — Status Roll-Up

PCPCAT (TeamPCP)	REACTIVATED post-pause	Apr 23 attribution; Mar 19 ops	TIER-1 DIRECT
IRONHARVEST (Multi-actor supply-chain)	Active expanding	Apr 1	TIER-1 DIRECT
ASHFALL (FS ransomware convergence)	Active; Coinbase Cartel re-frame Apr 27 (100+ victims)	Apr 2	TIER-1 DIRECT
DARKNEEDLE (Credential harvesting)	Active; EvilToken PhaaS folded	Apr 2	TIER-1 DIRECT
GHOSTFORGE (PhaaS + AiTM)	Active expanding; VENOM PhaaS folded	Apr 7	TIER-1 DIRECT
PRISMEX (CVE rapid weaponization)	Active; Marimo + Defender zero-days folded	Apr 8	TIER-1 DIRECT
TEAMSTORM (Cross-tenant helpdesk)	Active; UNC6692 SNOW folded	Apr 18	TIER-1 DIRECT-PRECEDENT
VERCEL-CASCADE	Active investigation	Apr 19	TIER-1
OVERDUE (Adobe Acrobat 0-day)	Active UNPATCHED	Early Apr	TIER-1
DEFENDER-STACK-PATTERN (<i>new this month, promoted</i>)	Sustained 2-cycle + 4 evidence streams	Apr 27	TIER-1 DIRECT
POST-AUTH-TRUST (<i>new this month, candidate</i>)	Emerging — 1-cycle; awaits corroboration	Apr 28	TIER-1 (pending)
FROSTARMADA (<i>new this month, promoted</i>)	APT28/GRU SOHO-router hijacking; 5K+ routers, 200+ orgs	Apr 8	TIER-1
OPERATION-EPIC-FURY (<i>new this month, promoted</i>)	Iran 144 financial-services attacks; CISA AA26-097A	Apr 8	TIER-1

Total active campaigns: 13 end-of-April (was 9 at start of month per BLUF master synthesis baseline; **+4 net** = DEFENDER-STACK-PATTERN + POST-AUTH-TRUST + FROSTARMADA + OPERATION-EPIC-FURY).

Detailed campaign briefs

PCPCAT (TeamPCP supply-chain) — TIER-1 DIRECT, REACTIVATED. Russian-speaking supply-chain operator partnered with Vect RaaS for affiliate mass-mobilization (300K BreachForums affiliates, 80–88% profit shares, Monero-only multi-sig escrow). 35-day window in Q1-Q2 produced compromises across Trivy, Checkmarx, LiteLLM, Telnix, 66+ npm packages, and a 340GB exfiltration from European Commission AWS. **Update 008 (Apr 27)** ended a ~19-day operational pause with three concurrent compromises (Checkmarx KICS, Bitwarden CLI cascade — adjacent to Shai-Hulud npm worm — xinferrence PyPI) and introduced the **CanisterSprawl** self-propagating npm worm. We assess (KA-4) it is **almost certain** (95%+; A-rated multi-source) that the pause was deliberate operational discipline, not group disruption.

IRONHARVEST (Multi-actor supply-chain wave) — TIER-1 DIRECT. Convergence cluster covering TeamPCP + UNC1069/Lazarus + commodity actors. April produced **1,700+ malicious packages** (DPRK/UNC1069/Lazarus attribution; CrowdStrike alias **STARDUST CHOLLIMA**) across npm/PyPI/Go/Rust ecosystems, Axios maintainer trojanization (v1.14.1 + v0.30.4 reaching 100M+ weekly downloads), Strapi plugin-ecosystem poisoning, CPUID

trojanized installers, Smart Slider WordPress plugin compromise, and **GlassWorm v2** OpenVSX VS Code extension worm (73 fake extensions). We assess it is **very likely** (80–95%) that what was boutique APT capability in 2024–2025 (SolarWinds-class) is now commodity-actor baseline.

DEFENDER-STACK-PATTERN (NEW campaign-class, promoted Apr 27) — TIER-1 DIRECT. Sustained 2-cycle pattern with 4 independent evidence streams: (1) CrowdStrike LogScale CVE-2026-40050 (security product as target); (2) BSI/CERT-Bund EDR Kaufratgeber comparative analysis (defender-stack research published openly, lowering attacker reconnaissance cost); (3) **BlueHammer / RedSun / UnDefend Windows Defender zero-days** released by researcher “Chaotic Eclipse” as the **Nightmare-Eclipse** tooling — Huntress observed in-the-wild exploitation Apr 16–20 with FortiGate VPN entry chain (SOCRadAr Apr 17 + Qualys Apr 22 mitigation guide); (4) **PoisonKiller** BYOVD signed-driver capability that kills CrowdStrike Falcon. We assess it is **very likely** (80–95%; KA-1) the pattern expands to 3–5 cycles. Sector implication: detection logic that assumes the EDR is running fails when the EDR is the target — out-of-band telemetry channel + EDR-of-EDR coverage required.

POST-AUTH-TRUST (NEW campaign-class candidate, 1-cycle emergence — awaits 2–3 cycle corroboration per ICD 203 standard) — TIER-1 pending. Single-cycle 4-source convergence: AiTM post-auth defenses (Microsoft, Apr 28), agentic-AI identity flaws (Microsoft Entra Agent ID privilege escalation, Apr 26), RAG pipelines security in enterprise SaaS (Apr 28), identity-as-perimeter doctrine (Apr 28). Conceptually identical to VERCEL-CASCADE attack class. Estimated per-firm exposure ceiling: \$15–100M (basis: Vercel-class precedent + AI-tool grant inheritance). **KA-2 invalidation: failure to observe a 5th independent source by end of May would downgrade to candidate-pattern.**

FROSTARMADA (APT28/GRU SOHO-router hijacking) — TIER-1. 5,000+ SOHO routers across 200+ organizations co-opted as persistent C2 staging infrastructure. Direct overlay onto remote-employee VPN-AiTM exposure and CISA-EDGE-BOTNET advisory class.

OPERATION-EPIC-FURY (Iran 144 financial-services attacks) — TIER-1. CISA AA26-097A federal-attribution joint advisory documenting Iran-nexus 144-finserv attack count + active PLC exploitation in US energy/water/government. Iran-nexus cluster previously had Handala/MOIS coverage; this is the named-campaign capstone with federal-attribution backing.

ASHFALL (FS ransomware convergence) — TIER-1 DIRECT. Six FS-sector ransomware operators active simultaneously: Akira, DragonForce, Nightspire, Qilin, IncRansom, **Coinbase Cartel** (reframed Apr 27 SOCRadar deep-dive: 100+ ransomware victims fueled by infostealer-credential pipeline — escalation from sector-adjacent to active Tier-2). Akira alone claimed 84 victims in March and two insurers in 24 hours April. **86% of Akira intrusions traced to SonicWall SSL VPN CVE-2024-40766** — load-bearing CVE for the surge. We assess (KA-5) it is **likely** (55–80%) the convergence reflects deliberate sector targeting rather than statistical coincidence.

Other active campaigns (DARKNEEDLE / GHOSTFORGE / PRISMEX / TEAMSTORM / VERCEL-CASCADE / OVERDUE): see prior briefs; April folded EvilToken PhaaS (MSTIC A-1, 44 mentions) into DARKNEEDLE; VENOM PhaaS (\$120/kit C-suite AiTM) into GHOSTFORGE; Marimo CVE + Defender zero-days into PRISMEX; UNC6692 SNOW into TEAMSTORM.

Top Adversaries by Tempo

TIER-1 DIRECT	TIER-2 ASCENDING	TIER-3 CONDITIONAL
TeamPCP 55 mentions · REACTIVATED	Akira PUNK SPIDER 49 April · 84 March victims · SonicWall CVE-2024-40766 86%	Play RECESS SPIDER NEW · closed-shop RaaS
UNC3944 / Scattered Spider 2016 SEC precedent · AA23-320A	Qilin 98 mentions · EDR-killer 300+ drivers	BlackFile NEW · The-Com-affiliated
Storm-1175 Medusa RaaS 58 mentions · pre-disclosure exploitation	UNC1069 / Lazarus STARDUST CHOLLIMA · 1,700 packages	DragonForce 20 mentions · UNC3944 collaborator
SLSH supergroup UNC3944 + ShinyHunters + LAP-SUS\$ federated	Stonefly DPRK OFAC sanctions · Medusa-affiliate	MuddyWater 26 mentions · Iran
UNC6692 NEW 33 mentions Mandiant A-1 · Teams + SNOW	Handala MOIS 24 mentions · destructive class	TA416 DarkPeony 16 mentions · OAuth EU diplomatic
UAT-4356 NEW Talos A-1 · Cisco Firestarter firmware backdoor	Coinbase Cartel REFRAMED Apr 27 · 100+ victims	Anubis NEW Marnell FS victim
		Lockbit5 NEW post-takedown variant

New library additions this month (post-audit): 11 actor cards — Stonefly (DPRK Andariel-Medusa-affiliate), BlackFile (The-Com-affiliated), Akira (PUNK SPIDER, RaaS-affiliate), Play (RECESS SPIDER, closed-shop), and post-audit authorship sprint adds UNC6692, UAT-4356, Anubis, Lockbit5, Sapphire Sleet, TheGentlemen + STARDUST CHOLLIMA alias merged into UNC1069 card. Library now at **~32 actor cards** (verify against vault count post-sprint).

Pending re-tier: Akira Tier-3 → Tier-1 promotion (pending forward-emulation queue ranking + Q2-Q3 calendar; load-bearing CVE-2024-40766 SonicWall added to CVE tracker).

CVE Landscape — April Disposition

CVE-2026-35616 FortiClient EMS	CISA KEV; sector-wide patch verification queued
CERT-Bund WID-SEC-2026-1047 Adobe Acrobat 0-day	UNPATCHED — workaround required (alt readers + sandboxing + AppLocker/WDAC)
CVE-2026-1340 Ivanti EPMM	CISA KEV; conditional applicability per-firm
CVE-2026-39987 Marimo Python	Patched; 9-hour weaponization signal recorded (KA-7 single-incident; devil's advocacy applied)
CVE-2026-32201 Microsoft Apr 14	Patch Tuesday; M365 deployment confirmation pending sector-wide
Juniper Junos Apr 9 patchday	Edge-device perimeter audit warranted
CVE-2026-20093 Cisco IMC	CISA KEV; CRITICAL CVSS 9.8; BMC-level persistence; UCS deployments at risk
CVE-2026-40050 CrowdStrike LogScale	Critical unauth path-traversal; affects self-hosted Falcon LogScale
MS Entra Agent ID flaw (CVE TBD)	Patched; legacy role-assignment audit required
CVE-2024-40766 SonicWall SSL VPN	86% of Akira intrusions vector ; sector SonicWall patch + credential-rotation audit
BlueHammer / RedSun / UnDefend Windows Defender LPE zero-days	Three “Nightmare-Eclipse” tooling 0days; active in-the-wild exploitation Apr 16-20 (Huntress) ; mitigations only (Qualys Apr 22 guide)
CISA SimpleHelp KEV batch (Apr 24)	SimpleHelp + Samsung + D-Link added to KEV with May 2026 federal deadline; RMM-platform abuse
CVE-2025-2884 Siemens TPM 2.0	Most-mentioned CVE in April corpus (56 mentions); sector hardware coverage check
CVE-2025-20333 / 20362 / 20363 Cisco IOS / IOS XE	Perimeter exposure; 14 mentions each; CISA + UAT-4356 firmware-resident backdoor adjacency
CVE-2026-32952 Azure go-ntlmssp integer overflow	Azure-adjacent for hybrid-cloud FS firms

Forward CVE class watch: SOHO-router botnets (CISA Apr 28) + FrostArmada APT28 5K+ router co-option — expands the perimeter definition to include remote-employee home equipment; new attack-surface class previously untreated by most FS programs.

Predictive Intelligence — Q3 Forward Emulation Queue

1	TeamPCP	Supply-chain → iPaaS data-exfil	87.3
2	Scattered LAPSUS Hunters	Workforce-OAuth → iPaaS-pivot → CMS DOM-harvest	85.4
3	UNC6783	Fake-Okta-page → identity-tenant compromise	82.0
4	Storm-2477-class	Email account compromise → mainframe pivot → COBOL recordkeeping system PII	81.0
5	UNC3944	Offshore privileged access → helpdesk interface (5-phase)	71.0
6 <i>(new this month)</i>	Akira	SonicWall VPN (CVE-2024-40766) → backup-job credential pivot → hypervisor (ESXi/Nutanix AHV)	TBD (Tier-1 re-tier pending)
7 <i>(new this month)</i>	Play	FortiOS → Citrix Bleed → Acronis EDR-eviction → intermittent encryption	TBD
8 <i>(post-audit add)</i>	UNC6692	Microsoft Teams IT-imPERSONATION → email-bombing → SNOW malware → cloud abuse	TBD (rank-eligible Q3)

Recommended Q3 cluster prioritization: The Com → Russian RaaS → Iran-nexus.

Q2 Purple-Team Pipeline Progress (sector reference cadence)

W3-4	Helpdesk-vishing (FLAGSHIP)	Approval pending at most sector firms
W4-5	TeamPCP supply-chain	Sequenced, prep ready
W5-6	Vercel-class OAuth cascade	Sequenced
W6-7	PRISMEX CVE rapid-weaponization	Sequenced
W7-8	DARKNEEDLE credential exposure	Sequenced
W7-8	GHOSTFORGE PhaaS + AiTM	Sequenced
W8-9	EDR-Resilience	Sequenced — Qilin escalation merits scope expansion
W9	Q2 retrospective	Scheduled
W4-5 NEW	Post-Auth-Trust Triad <i>(added April 28)</i>	New W4-W5 candidate session
W5-6 NEW	DEFENDER-STACK-PATTERN table-top <i>(added post-audit)</i>	BlueHammer/RedSun/UnDefend + PoisonKiller + LogScale CVE; out-of-band telemetry validation focus

Common first-cycle structural blockers across sector firms: BAS (SCYTHE/AttackIQ/Cymulate) tenant access; EDR admin-tenant scope; DE-team purple-team cadence confirmation. None can be cleared by RT alone — require CISO sign-off.

Decisions Queue — End-of-Month State (recurring CISO-tier items)

1	Approve W3-4 helpdesk-vishing flag-ship session	Regulatory triple-stack (2016 broker-dealer SEC Reg-S-ID precedent + NY DFS Feb 6 advisory + active SLISH female-voice recruitment)
2	Confirm Q2 P0 priorities (TeamPCP + Vercel-OAuth audits)	TeamPCP REACTIVATED Apr 27 reinforces urgency; UNC6692 SNOW expands scope
3	Red-team C2 selection (Sliver Q2 → Mythic Q3-Q4 typical)	Per-firm recommendation
4	Third-party-risk vendor concentration audit	Geo-concentration (Iran-nexus targeting class documented for Israeli-origin and US-allied vendors) + RMM concentration (CISA SimpleHelp KEV; Storm-1175 phishing-to-RMM playbook)
5	Stealer-log monitoring budget (\$130-225K/yr Hudson Rock + KELA + Flashpoint)	PIR-6 dark-web blind spot closure
6	Iran-nexus destructive-class tradecraft authoring under explicit ROE	Operator-led, gated; Operation Epic Fury (CISA AA26-097A) provides federal-attribution context
7	Mythos board-question briefing prep (Day-30)	Per Tenable Apr 14 template
8	Approve Post-Auth-Trust Triad as W4-W5 purple-team candidate	POST-AUTH-TRUST \$15-100M exceeds appetite at most firms
9 (NEW post-audit)	Approve DEFENDER-STACK-PATTERN tabletop (W5-6 candidate)	BlueHammer/RedSun/UnDefend + PoisonKiller + LogScale CVE; out-of-band telemetry validation; defender-stack hygiene budget

Voice-biometric vendor evaluation (\$2-5M annual FS-firm-typical based on industry analyst pricing benchmarks; ranges scale with firm AUM/revenue) — flagged for **first-cycle decision reframing** (was generic Q2 decision, escalated by Microsoft April 18 + UNC6692 Teams + Storm-0875 deepfake-voice context).

Carry-Over Tracker — End-of-Month Disposition (full inventory)

CO-1	FortiClient KEV	→ patch verify
CO-2	Adobe 0-day UNPATCHED	→ workaround deployed
CO-3	TeamPCP REACTIVATED	→ Q2 P0 priority
CO-4	UNC1069 / Lazarus 1,700 packages	→ dependency-tree audit
CO-5	ASHFALL FS-ransomware tempo	→ Q4 tabletop
CO-6	Anthropic Mythos	→ Day-30 board prep
CO-7	Iran cyber-threat-outlook	→ Op Epic Fury / CISA AA26-097A
CO-8	China-nexus covert networks	→ CISA Joint Apr 21-23
CO-9	Vercel cascade	→ Q2 P0 priority
CO-10	Microsoft Apr 18 helpdesk	→ W3-4 flagship session
CO-11	MS Entra Agent ID	→ patched, audit pending
CO-12	LogScale CVE-2026-40050	→ self-host check
CO-13	BlackFile watchlist	→ 30-90d horizon
CO-14	CISA SOHO botnet	→ perimeter expansion
CO-15	DEFENDER-STACK-PATTERN	→ campaign-class + 4 evidence streams
CO-16	POST-AUTH-TRUST	→ 1-cycle; awaits 2-3 cycle corroboration

Total open carry-overs: 16 (was 5 entering April → +11 net; structural threat-landscape expansion). All have action plans documented in carry-over master tracker.

Strategic Implications for FS CISO — May–June

- POST-AUTH-TRUST exposure ceiling exceeds typical sector risk appetite.** \$15-100M per-firm dollar exposure on a candidate campaign-class label whose attack surface is identical to VERCEL-CASCADE. Warrants board-level surfacing and a board-question prep brief at most FS firms running OAuth-integrated cloud stacks. **KA-2 awaits 2-3 cycle corroboration before formal promotion.**
- DEFENDER-STACK-PATTERN now has 4 independent evidence streams in active in-the-wild exploitation.** LogScale CVE + BSI/CERT-Bund EDR analysis + BlueHammer/RedSun/UnDefend Windows Defender zero-days + PoisonKiller signed-driver Falcon-killer. **Detection logic at most firms assumes the EDR is running; if the EDR is the target, the assumption fails.** Out-of-band telemetry channel + EDR-of-EDR coverage required.
- Akira insurance-vertical surge converts to operational FS-direct ransomware risk** (KA-5 watch — May reversion-to-mean would invalidate). Two insurers struck in 24 hours April; **86% of intrusions traced to SonicWall SSL VPN CVE-2024-40766** (now in CVE tracker P1). Insurance and retirement-services firms with M&A-acquired sub-units need full SonicWall inventory + credential rotation regardless of patch state.
- TeamPCP ~19-day pause was deliberate operational discipline, not group disruption** (KA-4). Update 008 demonstrated three concurrent compromises plus a self-propagating worm capability that did not exist in prior updates. Sector vendor stacks remain directly exposed. **Reinforced by GlassWorm v2** (OpenVSX VS Code extension worm) and **CISA SimpleHelp KEV batch** (RMM platform abuse).
- UNC6692 + UAT-4356 expand the active-attribution roster mid-month** (Mandiant A-1 + Talos A-1). UNC6692 directly extends TEAMSTORM helpdesk-impersonation tradecraft with custom SNOW malware. UAT-4356 / Cisco Firestarter establishes firmware-resident backdoor as a sustained perimeter-compromise class. Cisco-stack FS firms should treat as active rather than theoretical.

Recommended May-June Focus

1. **Clear first-cycle structural blockers** (BAS tenant + EDR admin scope + DE cadence) — required to start any purple-team session
2. **Execute helpdesk-vishing flagship session W3-4** — regulatory triple-stack, lowest-friction-to-measure
3. **Promote Akira to Tier-1 active emulation** — composite scoring + Q3 calendar slot allocation; CVE-2024-40766 SonicWall load-bearing
4. **Surface POST-AUTH-TRUST to Legal/CISO** — risk-appetite ceiling triggered at most firms; KA-2 corroboration watch
5. **Author DEFENDER-STACK-PATTERN tabletop** — out-of-band telemetry validation focus; W5-6 purple-team candidate
6. **Stand up stealer-log marketplace monitoring** (\$130-225K/yr) — closes PIR-6 blind spot
7. **Add CISA SOHO botnet advisory + FrostArmada to perimeter doctrine** — remote-employee home equipment + APT28 router-hijack staging now in scope
8. **Validate out-of-band firewall recovery procedure** — Play SonicWall password-reset takeover scenario (Recess Spider TTP) + UAT-4356 Cisco Firestarter cold-start procedure
9. **RMM concentration audit** — CISA SimpleHelp KEV batch + Storm-1175 phishing-to-RMM playbook adjacency
10. **Iran-nexus tradecraft authorship** — Operation Epic Fury (CISA AA26-097A) + Handala/MOIS destructive class

Recurring Monthly Template Spec (v1.1)

This document is the recurring April→May→June→... shape. The standing sections are:

1. **Frontmatter** — title, period, audience, deliverable_type, tags / aliases / date_created (v1.1)
2. **Executive BLUF** — 3 paragraphs (what changed / what's new / what's queued)
3. **Analytic Tradecraft Standards** — ICD 203/206/207 framework + **Key Assumptions Check (KA-1..N) with invalidation indicators (v1.1 standing element) + single-source devil's-advocacy flagging (v1.1)**
4. **THREATCON Determination + I&W Matrix** + cycle-on-cycle trend
5. **Month-in-review timeline** — Gantt with posture trend + major events
6. **Top 10 cycle events** — with sector implication
7. **New campaign-class labels promoted this month** — promoted vs candidate (per ICD 203 cross-cycle continuity)
8. **Active campaigns roll-up** — status table + detailed per-campaign briefs
9. **Top adversaries by tempo** — with mermaid tier mindmap
10. **CVE landscape** — what's resolved / what's lingering / what's new
11. **PI engine forward emulation queue** — Q3+ ranking
12. **Purple-team pipeline progress**
13. **Decisions queue end-of-month state**
14. **Carry-over tracker disposition** — all entries in flowchart OR explicit subset criterion (v1.1)
15. **Strategic implications for FS CISO** (3-5 sentences)
16. **Recommended next-month focus**
17. **Sources** — Admiralty-rated upstream products with URLs (v1.1)

Cadence: 28th of each month (or last business day, whichever earlier). **Distribution:** FS CISO primary; RT + DE; Legal/CLO conditional on risk-appetite-ceiling triggers. **Length target:** 3,500-4,500 words; 14-17 min read (v1.1 expansion to accommodate KAC + per-campaign briefs). **Authorship pre-publication checklist (v1.1):** Math reconciliation gate (cycle counts, actor totals, campaign deltas cite vault sources) + sector-scrub list (VFA / Voya / FIS Omni / OneAmerica / SnapLogic / IBM ISAM / Cognizant rebadging / Workday pre-hire / 4 Entra tenants — none

should appear in sector-portable distribution) + ACH/KAC demonstration requirement (show worksheets for top 1-2 P1 items).

Sources

Internal cycle products: - April 2026 daily intelligence cycle dossiers (9 daily + 1 mega-catchup synthesis Apr 11-25 + 1 monthly rollup + 1 master synthesis = 12 BLUF products) - Carry-over master tracker (CO-1 through CO-16) - CVE priority tracker (post-audit batch update) - April 2026 actor tempo tracker - Advisory ingestion files (April 25-28 cycle + post-audit backlog) - Threat-actor cards (Stonefly / BlackFile / Akira / Play newly added; UNC6692 / UAT-4356 / Anubis / Lockbit5 / Sapphire Sleet / TheGentlemen post-audit sprint)

External (Admiralty-rated, with URLs): - Microsoft / MSTIC (A-1) — microsoft.com/security/blog/ (April 18 cross-tenant helpdesk-impersonation playbook; April 26 Entra Agent ID; EvilToken PhaaS coverage) - CISA / CISA Joint Advisories (A-1) — cisa.gov/news-events/cybersecurity-advisories (Apr 9 FortiClient KEV; Apr 21-23 China-Nexus Covert Networks; Apr 24 SimpleHelp/Samsung/D-Link KEV batch; Apr 28 SOHO botnet; AA26-097A Iran PLC + Operation Epic Fury) - Mandiant / Google TAG / GTIG (A-1) — cloud.google.com/blog/topics/threat-intelligence/ (UNC6692 social engineering + custom malware Apr 21) - Cisco Talos (A-1) — blog.talosintelligence.com/ (UAT-4356 Firestarter Apr 24) - CrowdStrike Intelligence (A-2) — STARDUST CHOLLIMA / PUNK SPIDER / RECESS SPIDER actor designations - Unit 42 (A-2) — Coinbase Cartel reframe; BlackFile attribution - Sophos / At-Bay (B-2) — Akira SonicWall 86% vector - BSI / CERT-Bund (A-2) — bsi.bund.de/ (EDR Kaufratgeber; WID-SEC-2026-1047 Adobe Acrobat) - Huntress (B-1) — huntress.com/blog/ (BlueHammer/RedSun/UnDefend in-the-wild Apr 16-20; FortiGate VPN entry chain) - SOCRadar (B-2) — socradar.io/blog/ (BlueHammer/RedSun/UnDefend Apr 17 analysis; Coinbase Cartel Apr 27) - Qualys (B-2) — blog.qualys.com/qualys-insights/ (RedSun mitigation guide Apr 22) - ZeroFox / Halcyon / RH-ISAC (B-2) - Dataminr (B-1) — SLSH female-voice-visher recruitment Feb 22 - ReliaQuest / Resecurity (B-2) - NY DFS / SEC / OFAC (A-1) — Reg S-P 2024, 8-K Item 1.05, 10-day OFAC sanctions reporting - Wordfence (B-2) — AI-assisted vulnerability submissions: 16% → 66% share, +453% volume - UK NCSC (A-1) — UAT-4356 joint advisory - Reddit / r/sysadmin / r/netsec (D — flagged single-source devil's-advocacy) — Vercel BreachForums sale verification (KA-3)

End of April 2026 FS-Sector Monthly Brief.

Next deliverable: May 2026 FS-Sector Monthly — published end of May 2026 per template spec v1.1 above.